

ID	Category	Asset	Threat
A001	IT	Customer Database	External Hacker
A002	IT	Web Server	Malware
A003	IT	Network Router	Network Intrusion
A004	IT	Employee Laptop	Theft
A005	IT	Firewall	Unauthorized Configuration Changes
A006	People	Employee Account	Malicious Insider
A007	People	CEO Email Account	Phishing Attack
A008	People	Administrator Account	Credential Theft
A009	People	HR Portal	Social Engineering
A010	Physical	Server Room	Unauthorized Physical Access
A011	Physical	CCTV System	Tampering
A012	Physical	Office Building	Fire
A013	Third-Party	Cloud Storage Service	Data Breach
A014	Third-Party	Payment Gateway Provider	Third-Party Security Breach
A015	Third-Party	Shipping Partner API	Data Leakage

Risk Scoring

Likelihood	Value
Low	1
Medium	2
High	3

Impact	Value
Low	1
Medium	2
High	3

Risk Score = Likelihood × Impact

Vulnerability	Likelihood	Impact	Risk Score
Weak access controls	High	High	9
Unpatched operating system	High	High	9
Misconfigured routing table	Medium	Medium	4
No full-disk encryption	Medium	High	6
Outdated firewall rules	High	High	9
Excessive access privileges	Medium	High	6
Lack of Multi-Factor Authentication (MFA)	High	High	9
Weak password policy	High	High	9
Lack of employee security awareness	Medium	High	6
Weak physical access controls	Medium	High	6
Default administrator credentials	Medium	Medium	4
Inadequate fire detection and suppression systems	Low	High	3
Misconfigured cloud storage permissions	Medium	High	6
Vendor security weaknesses	Medium	High	6
Insecure API authentication	Medium	High	6

Suggested Control

Implement Role-Based Access Control (RBAC) and Least Privilege

Establish a regular patch management process

Perform regular configuration reviews and security audits

Enable full-disk encryption and remote device wipe

Review and update firewall rules regularly

Apply Least Privilege and perform periodic access reviews

Enable MFA and conduct phishing awareness training

Enforce strong password policy and MFA

Conduct regular security awareness training

Implement biometric access and CCTV monitoring

Change default credentials and perform regular maintenance

Install and regularly test fire detection and suppression systems

Regularly review cloud configurations and enforce least privilege

Perform vendor risk assessments and require security certifications

Implement secure API authentication and encryption